

A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the

Ethical and Practical Risks of Testing without Informing the IT Department

When a client asks a security tester (ethical hacker) to test their systems without informing the IT department, the goal is often to evaluate how well the IT team detects and responds to a real cyberattack. This is known as a red team or blind security assessment. While this can be useful, it also creates several ethical and practical risks

(a) Lack of Proper Authorization

→ If the IT department is not informed, they may think the attack is real.

→ This can lead to confusion and unnecessary panic

(b) Trust Issues

- If employees later discover the list without explanation, they may lose trust in management
- It may affect teamwork and morale.

(c) Privacy Concerns

- During testing, sensitive employee & customer data could be accessed
- The tester must protect confidential information and follow privacy laws

2. Practical Risks

a) Service Disruption

- Security testing may accidentally slow down & crash servers
- This can interrupt normal business operations

b) Incident Response Activation

The IT team may:

- Block the tester's IP address
- Shut down systems.

(c) Legal Problems

- Without clear authorization, the tester could be accused of unauthorized access
- written approval is essential for legal protection

(d) Data Loss

- Aggressive testing may damage or delete important data if safeguards are not in place

How to Structure the Engagement

To protect both the client and yourself, the engagement should be carefully planned.

Step 1: obtain written Authorization

- Get signed approval from senior management.

→ Clearly state:

- Scope of testing
- Target systems
- Testing techniques

Step 2 Define the Scope

Specify :

- Systems to be tested
- Systems that must not be touched
- Testing limits
- Time windows

Step 3 : Establish Rules of engagement

include → what attacks are allowed

- what attacks are prohibited
- Emergency Stop Procedure
- Communication plan
- Reporting requirements

Step 4 : Emergency Contacts

Maintain a Confidential list of People who know about the test

- CEO
- CISO
- Security Manager

Steps Protect data

- Avoid unnecessary access to sensitive information
- Encrypt collected evidence
- Store reports securely.
- Delete temporary data after the engagement

Step 6: Prepare a final Report

- The report should include:
- Vulnerabilities found
- Risk level
- Impact
- Recommendation
- Detection performance of the IT team